L'impersonation de jetons (token impersonation en anglais) est un concept souvent utilisé dans le contexte de la sécurité informatique et de l'authentification pour permettre à un utilisateur ou à une application d'agir au nom d'un autre utilisateur ou entité, généralement avec des autorisations spécifiques. Cela peut être utilisé dans divers scénarios, tels que l'accès à des ressources partagées ou la délégation de certaines autorisations.
Voici comment cela fonctionne généralement et à quoi cela sert :

1. **Authentification initiale** : Pour utiliser l'impersonation de jetons, un utilisateur doit s'authentifier de manière sécurisée, généralement en fournissant un nom d'utilisateur et un mot de passe, ou en utilisant d'autres méthodes d'authentification, comme les clés API, les certificats, ou les jetons d'accès.

2. **Obtention d'un jeton d'impersonation** : Une fois authentifié, l'utilisateur peut demander un jeton d'impersonation. Ce jeton est généralement généré par une autorité de sécurité ou un serveur d'authentification. Le jeton d'impersonation est un jeton qui atteste de l'identité de l'utilisateur authentifié et de ses autorisations.

3. **Utilisation du jeton d'impersonation** : L'utilisateur peut utiliser ce jeton d'impersonation pour accéder à des ressources ou effectuer des opérations en tant qu'une autre entité ou utilisateur. Le système qui vérifie le jeton d'impersonation attribue les autorisations spécifiques associées à l'entité ou à l'utilisateur au nom duquel l'impersonation est réalisée.

Exemples d'utilisation de l'impersonation de jetons :

- **Support technique** : Un administrateur système peut utiliser l'impersonation pour accéder aux comptes d'utilisateurs pour résoudre des problèmes ou effectuer des tâches de maintenance sans connaître les mots de passe des utilisateurs.
- **Applications tierces** : Une application peut obtenir un jeton d'impersonation pour accéder à des ressources au nom d'un utilisateur, avec les autorisations de cet utilisateur, afin d'automatiser certaines tâches sans stocker les informations d'authentification de l'utilisateur.
- **Accès à des ressources partagées** : Dans un environnement d'entreprise, un administrateur peut obtenir un jeton d'impersonation pour accéder aux ressources partagées, même si elles sont normalement restreintes à d'autres utilisateurs.

L'impersonation de jetons est une fonctionnalité puissante mais doit être mise en œuvre avec soin, car elle comporte des risques de sécurité potentiels. Il est essentiel de contrôler et de surveiller les utilisations d'impersonation pour s'assurer qu'elles sont conformes aux politiques de sécurité de l'organisation

Adapter à notre utilisation avec faiblesses

Liens:
-https://sensepost.com/blog/2022/abusing-windows-tokens-to-compromise-active-directory-without-touching-lsass/

-https://www.youtube.com/watch?v=gtg_rmLW60I